

NIST CSF 2.0 GAP ASSESSMENT

Stage 2 — Maturity Rating Scale & Assessment Methodology

Document Control	Details
Company	LearnSphere EdTech
Assessment	NIST CSF 2.0 Gap Assessment
Stage	Stage 2 — Build a Maturity Rating Scale
Business Context	Cloud LMS for schools; approximately 150–250 employees; AWS-hosted
Risk Context	Sensitive personal data, including information relating to minors
Primary Focus	Govern/Identify: parental consent and data minimization; Protect: access controls for student records
Prepared By	Mr. Meejan Shaikh – GRC Analyst
Reviewed By	Information Security Manager
Approved By	CISO

1. Purpose

This document establishes the maturity rating methodology to be used for LearnSphere EdTech's NIST Cybersecurity Framework (CSF) 2.0 Gap Assessment. The scale provides a consistent way to characterize the extent to which selected cybersecurity outcomes are being achieved and to compare the current posture with the desired target state.

The assessment is intentionally based on an existing but partially mature security posture. LearnSphere is assumed to have some ad hoc cybersecurity practices rather than operating from a blank slate.

2. Standard Reference

The primary reference is the NIST Cybersecurity Framework (CSF) 2.0. NIST describes the CSF as a taxonomy of high-level cybersecurity outcomes and organizes the Core into six Functions: GOVERN, IDENTIFY, PROTECT, DETECT, RESPOND and RECOVER. NIST also uses Organizational Profiles to describe current and target cybersecurity posture and support gap analysis.

For this hands-on assessment, the required 0–4 maturity scale is an internal project scoring mechanism. It is used to make the assessment consistent and measurable; it is not presented as an official NIST maturity score. NIST CSF 2.0 itself does not prescribe a single maturity scoring model.

3. Assessment Context — LearnSphere EdTech

Context Area	Assessment Basis
Organization	LearnSphere EdTech
Industry	Education Technology (EdTech)
Service	Cloud-based Learning Management System (LMS) for schools
Hosting	AWS cloud environment
Workforce	Approximately 150–250 employees
Information Risk	Sensitive personal and student information
Minors' Data Focus	Children's/student data requires stronger governance and protection considerations
Govern / Identify Focus	Parental-consent governance and data-minimization practices
Protect Focus	Access control and protection of student records

4. Maturity Rating Scale

Each applicable NIST CSF outcome will receive one maturity rating from 0 to 4. The rating should reflect the condition supported by the assessment evidence, not the analyst's expectation of what should exist.

Score	Maturity Level	Definition
0	Not Performed	The outcome is not performed, or there is no credible evidence that it is addressed.
1	Ad Hoc	Activities are performed inconsistently, informally, or reactively without a reliable repeatable approach.
2	Repeatable	The practice is performed with some consistency and can be repeated, but documentation, ownership, coverage, or measurement may be incomplete.
3	Defined	The practice is formally documented, assigned to responsible roles, consistently implemented, and integrated into normal processes.
4	Managed / Optimized	The practice is consistently managed, measured, reviewed for effectiveness, and continuously improved using results, risk information, and lessons learned.

5. Rating Decision Rules

- Rate the outcome based on objective evidence and the actual operating condition assumed for the fictional company.
- Where evidence is incomplete, do not automatically award a higher score; record the limitation and use the lower defensible rating.
- A score of 3 requires more than a policy existing on paper; implementation and ownership must also be demonstrable.
- A score of 4 requires evidence of measurement, management review, effectiveness monitoring, or continual improvement.
- Different outcomes may legitimately receive different scores; the company should not receive one blanket maturity score.
- Ratings should be supported by evidence such as policies, procedures, access-review records, configuration reports, logs, tickets, meeting minutes, risk registers, training records or audit evidence.

6. LearnSphere-Specific Rating Interpretation

Score	Parental Consent / Children's Data	Student Record Access Controls
0	No defined consent requirement or evidence mechanism.	No defined access-control process for student records.
1	Consent handling may occur informally or case-by-case; evidence is inconsistent.	Access may be granted manually; reviews and least-privilege decisions are inconsistent.
2	A repeatable consent process exists for some workflows, but coverage/evidence is incomplete.	Role-based access or approval practices exist, but periodic certification and privileged-access controls are incomplete.
3	Consent requirements, evidence retention, ownership and review are formally defined and consistently implemented.	RBAC/least privilege, approvals, MFA where applicable, and periodic access reviews are defined and consistently performed.

4	Consent controls are measured, monitored, reviewed and improved using exceptions, complaints, incidents and data-governance metrics.	Access is continuously governed using automated controls, periodic certification, privileged-access monitoring, metrics and improvement actions.
---	--	--

7. How the Scale Will Be Used in the Gap Assessment

Assessment Step	Application
Current State	Assign a 0–4 score to the applicable NIST CSF outcomes based on the assumed existing posture.
Target State	Define the desired 0–4 state appropriate to LearnSphere's risk, business objectives and data sensitivity.
Gap	Calculate the difference between Current and Target ratings and explain the underlying weakness.
Priority	Consider data sensitivity, risk impact, regulatory exposure, likelihood, business importance and implementation effort.
Roadmap	Convert material gaps into remediation actions with accountable owners and target timeframes.
Reassessment	Re-score the outcome after remediation to demonstrate measurable improvement.

8. Example — Student Record Access

Example current-state scenario: LearnSphere has role-based access for the LMS, but periodic access certification for student records is not consistently evidenced. Privileged administrative access is also not uniformly governed.

Assessment rating: 1 — Ad Hoc, if access decisions and reviews occur inconsistently without a reliable documented cycle.

Target rating: 3 — Defined, where student-record access is formally role-based, approvals are documented, least privilege is enforced, and periodic reviews are consistently completed.

Resulting gap: 2 maturity levels. The gap would then be investigated and converted into specific remediation actions, such as formal access certification, stronger privileged-access governance and evidence retention.

9. Example — Parental Consent & Data Minimization

For children's data, the assessment should examine whether LearnSphere has a defined and repeatable approach to determining what information is collected, why it is needed, how consent requirements are addressed, how consent evidence is retained, and how unnecessary collection is prevented.

Assessment Question	Evidence Example
Is the purpose for each material category of children's data documented?	Data inventory / data-flow record
Is collection limited to information necessary for the stated purpose?	Data-minimization review / application field inventory
Are applicable parental-consent requirements translated into workflow requirements?	Product/privacy requirements and workflow design
Can consent status and relevant evidence be demonstrated?	Consent record / audit trail
Are exceptions, changes and reviews managed?	Change records / review minutes / exception register

10. Governance & Ownership

Role	Responsibility in This Methodology
CISO	Executive accountability; approves assessment methodology and target posture.
Information Security Manager	Reviews assessment consistency, challenges ratings and oversees remediation governance.

GRC Analyst	Performs evidence-based assessment, documents rationale, maintains gap register and prepares reporting.
Data / Privacy Owner	Provides children's-data, consent, minimization and retention evidence.
IAM / Cloud Security Owner	Provides student-record access, privileged access, MFA and cloud identity evidence.

11. Deliverable Produced from This Methodology

This maturity scale becomes the scoring foundation for the next NIST CSF 2.0 assessment activities. The resulting assessment package should contain a Current Organizational Profile, Target Organizational Profile, Gap Register, prioritized remediation roadmap and management summary. NIST specifically describes Current and Target Profiles as mechanisms for characterizing posture and identifying gaps.

12. Approval

Role	Name	Signature	Date
Prepared By	Mr. Meejan Shaikh – GRC Analyst		
Reviewed By	Information Security Manager		
Approved By	CISO		